

IAM-99: Best Practice Summary

Series: IAM | Notebook: 99 | Created: March 2026 | Last Updated: 04/03/2026

Overview

This notebook distills every actionable best practice from the IAM series (IAM-01 through IAM-12) into a single reference. Each practice is definitive: it states exactly what to configure, at what priority, and in which category. Use this as a pre-deployment checklist and ongoing governance audit sheet.

Table of Contents

- 1. [Authentication and SSO](#)
- 2. [Group Architecture](#)
- 3. [Policy Design](#)
- 4. [Boundaries and Data Partitioning](#)
- 5. [User Lifecycle and Provisioning](#)
- 6. [Tokens and Service Accounts](#)
- 7. [Audit and Compliance](#)
- 8. [Multi-Environment and Governance](#)
- 9. [Troubleshooting and Operations](#)

Priority Legend

Priority	Meaning
Critical	Must implement before production. Security risk if omitted.
Recommended	Should implement for enterprise-grade operations.
Optional	Beneficial for mature organizations or specific compliance needs.

1. Authentication and SSO

Source: IAM-01, IAM-02

#	Best Practice	Recommended Setting/Value	Priority	Category
1	Configure SSO before creating groups or policies	SAML 2.0 IdP integration in Account Management > Identity providers	Critical	Auth
2	Use SAML 2.0 with signed assertions	IdP configuration: Sign assertions = Required	Critical	Auth

#	Best Practice	Recommended Setting/Value	Priority	Category
3	Set NameID format to email	IdP SAML app: Name ID format = EmailAddress	Critical	Auth
4	Include groups attribute in SAML assertion	IdP attribute statement: name = groups , value = user group memberships	Critical	Auth
5	Enforce MFA at the IdP level for all Dynatrace users	IdP sign-on policy: Require MFA for the Dynatrace SAML application	Critical	Auth
6	Use phishing-resistant MFA factors	Factor priority: WebAuthn > TOTP > Push > SMS. Disable SMS if possible	Recommended	Auth
7	Maintain at least one local admin account	Local Dynatrace account (not SSO-dependent) with account-iam-admin , stored in enterprise vault	Critical	Auth
8	Test both SP-initiated and IdP-initiated login	Verify: Dynatrace login redirects to IdP AND IdP portal tile lands in Dynatrace	Recommended	Auth
9	Enable encrypted assertions for sensitive environments	IdP SAML configuration: Encrypt assertions = Enabled	Optional	Auth

2. Group Architecture

Source: IAM-03, IAM-06

#	Best Practice	Recommended Setting/Value	Priority	Category
10	Use the Matrix group pattern for enterprises (>50 users)	Groups = <scope>-<team>-<role> (e.g., dt-checkout-admins , dt-checkout-viewers)	Recommended	Groups
11	Prefix all Dynatrace groups with dt-	Naming: dt-<team>-<role> , lowercase, hyphens only, under 50 characters	Critical	Groups
12	Use explicit SAML group mappings, not auto-create	Account Management > Identity providers > Group mapping: do NOT enable auto-create groups	Critical	Groups
13	Assign all access via groups, never directly to users	Direct user assignment only for break-glass, time-limited scenarios	Critical	Groups
14	Designate an owner for every group	Group description must include owner name/team and purpose	Recommended	Groups
15	Create a default viewer group for all authenticated users	Group dt-all-viewers with environment-viewer policy, mapped to IdP all-employees group	Recommended	Groups
16	Create a break-glass admin group, empty by default	Group dt-breakglass-admins with account-iam-admin + environment admin. Membership = 0 at rest. Temporary membership < 24h only	Critical	Groups
17	Enforce separation of duties via incompatible group pairs	Users must NOT be in both: Production Admins + Development Editors, Security Auditors + Platform Admins, Token Managers + Application Users	Recommended	Groups
18	Review admin group membership monthly	Admin groups: monthly. Editor groups: quarterly. Viewer groups: semi-annually	Critical	Groups

3. Policy Design

Source: IAM-04, IAM-10

#	Best Practice	Recommended Setting/Value	Priority	Category
19	Start with default policies, add custom only when needed	Use <code>environment-viewer</code> , <code>environment-editor</code> , <code>environment-admin</code> as baseline. Create custom policies for team-scoped or capability-scoped access	Recommended	Policies
20	Layer default + custom policies per group	Group gets <code>environment-viewer</code> (base read) + custom policy (scoped write). Never rely on custom policy alone for read access	Recommended	Policies
21	Use <code>\${bindParam:...}</code> templated policies for multi-team scoping	One template policy + N bindings instead of N identical policies. Naming: <code>tpl-<scope>-<permission></code>	Recommended	Policies
22	Apply least privilege: grant minimum required <code>service:resource:action</code>	Each policy statement = <code>ALLOW <service>: <resource>:<action></code> . No wildcards unless role genuinely needs broad access	Critical	Policies
23	Use WHERE conditions to scope storage access by security context	<code>ALLOW storage:logs:read WHERE storage:dt.security_context = "team-name"</code>	Critical	Policies
24	Use <code>storage:bucket-name</code> conditions for hard data isolation	<code>ALLOW storage:logs:read WHERE storage:bucket-name = "team_logs"</code> for compliance-grade team isolation	Critical	Policies
25	Combine bucket + security context for defense in depth	<code>WHERE storage:bucket-name = "team_logs" AND storage:dt.security_context = "team"</code>	Optional	Policies
26	Version-control all policies via GitOps (Monaco or Terraform)	Store policy YAML in git. PR review before apply. CI/CD deploys to environments	Recommended	Policies
27	Test every custom policy in a non-production environment first	Create test group + test user, verify intended access works AND unintended access is blocked	Critical	Policies

4. Boundaries and Data Partitioning

Source: IAM-05

#	Best Practice	Recommended Setting/Value	Priority	Category
28	Define boundaries across all three domains	Every boundary must include: <code>environment:management-zone</code> , <code>storage:dt.security_context</code> , AND <code>settings:dt.security_context</code>	Critical	Boundaries
29	Include "shared" context in team boundaries	<code>storage:dt.security_context IN ("team-a", "shared", "infrastructure")</code> for infrastructure visibility	Recommended	Boundaries
30	Achieve >95% security context coverage on entities	Query: <code>fetch dt.entity.service</code> and check <code>countIf(isNotNull(dt.security_context)) / count()</code> . Target: >95%	Critical	Boundaries

#	Best Practice	Recommended Setting/Value	Priority	Category
31	Use Entity Enrichment rules (not auto-tags) for security context	Settings > Entity Enrichment: assign <code>dt.security_context</code> based on host group, K8s namespace, or host property	Recommended	Boundaries
32	Plan Grail buckets carefully: names are immutable, data cannot move	Naming: <code><org>_<datatype>_<retention></code> (e.g., <code>teamA_logs_90d</code>). Max 80 buckets per environment. 1 data type per bucket	Critical	Boundaries
33	Set bucket ingest target at ~1 TB/day per bucket	Optimal: ~1 TB/day. Acceptable: 1-3 TB/day. Hard limit: 3 TB/day	Recommended	Boundaries
34	Use Primary Grail Fields for pipeline routing	Route to buckets based on <code>k8s.cluster.name</code> , <code>k8s.namespace.name</code> , <code>aws.account.id</code> , <code>azure.subscription.id</code> , <code>dt.host_group.id</code>	Recommended	Boundaries
35	Use wildcards only for admin/platform groups	<code>environment:management-zone</code> IN (" <code>*</code> ") only for groups that genuinely need cross-team access	Critical	Boundaries

5. User Lifecycle and Provisioning

Source: IAM-06

#	Best Practice	Recommended Setting/Value	Priority	Category
36	Use SCIM for automated user/group sync (>50 users)	IdP SCIM endpoint to Dynatrace. Enable: Create Users, Update Attributes, Deactivate Users, Push Groups	Recommended	Lifecycle
37	Use JIT provisioning only if SCIM is unavailable	Account Management > Identity providers > Enable auto-provision on login. Always configure a default group	Optional	Lifecycle
38	Immediately revoke all access on employee termination	Same-day: disable in IdP (SCIM auto-deactivates), revoke all API tokens, deactivate OAuth clients, transfer dashboard ownership	Critical	Lifecycle
39	Revoke user-created tokens on offboarding	Account Management > API tokens > Filter by created-by user > Revoke all. Tokens persist after user deactivation until explicitly revoked	Critical	Lifecycle
40	Create dedicated groups for external users	Group <code>external-<company>-<role></code> (e.g., <code>external-acme-consultants</code>). Apply least-privilege policies with WHERE clauses. Set time-bound access	Recommended	Lifecycle
41	Enforce MFA for all external accounts	External users authenticating via local Dynatrace account must have MFA enabled	Critical	Lifecycle
42	Conduct quarterly access reviews for external users	Review all external user access quarterly. Revoke immediately when engagement ends	Recommended	Lifecycle

6. Tokens and Service Accounts

Source: IAM-06, IAM-12

#	Best Practice	Recommended Setting/Value	Priority	Category
43	One OAuth client per application	Never share clients across apps. Naming: <code><app>--<environment>--<purpose></code>	Critical	Tokens
44	Grant minimum OAuth scopes	Only grant scopes the integration needs. Common: <code>storage:logs:read</code> , <code>storage:metrics:read</code> , <code>settings:objects:read</code>	Critical	Tokens
45	Set short OAuth token lifetimes	Token lifetime: hours to days, not weeks. Rotate client secrets every 90 days	Recommended	Tokens
46	Use descriptive token names	Naming: <code><purpose>--<scope>--<owner></code> (e.g., <code>cicd-pipeline-metrics-reader</code>). Never use generic names	Recommended	Tokens
47	Set expiration dates on all API tokens	Every token must have a defined expiry. Default rotation schedule: 90 days	Critical	Tokens
48	Store tokens in a secrets manager	Use CyberArk, HashiCorp Vault, AWS Secrets Manager. Never in code, shared environment variables, or wiki pages	Critical	Tokens
49	Maintain a service account inventory	Document: owner, purpose, scopes, expiry date, rotation schedule for every OAuth client and API token. Review quarterly	Recommended	Tokens
50	Use OAuth2 client credentials for new integrations	Prefer OAuth over API tokens for all new automation. API tokens only for legacy compatibility	Recommended	Tokens

7. Audit and Compliance

Source: IAM-07

#	Best Practice	Recommended Setting/Value	Priority	Category
51	Set audit log retention to match compliance framework	SOC2: 1 year. SOX: 7 years. HIPAA: 6 years. PCI-DSS: 1 year online + archive	Critical	Audit
52	Monitor failed logins and alert on brute-force patterns	Alert: >5 failed logins from same user in 10 min = Warning. >20 failed logins any user in 10 min = Critical	Critical	Audit
53	Alert on all admin actions outside business hours	Alert: any audit event matching admin activity where hour < 8 or hour > 18 = Warning	Recommended	Audit
54	Alert on all policy creation, modification, and deletion	Alert: audit events with policy created/modified/deleted = Info severity	Recommended	Audit
55	Build a compliance dashboard with five sections	Sections: Authentication trend (line), Failed access by day (bar), User changes (table), Admin activity (table), Token operations (table)	Recommended	Audit
56	Conduct access reviews at defined frequency by role	Admin groups: quarterly. Editor groups: semi-annually. Viewer groups: annually. Account Admins: monthly	Critical	Audit
57	Remove users inactive for 90+ days	Query users with last login >90 days ago. Disable accounts. Transfer asset ownership. Revoke tokens	Recommended	Audit

#	Best Practice	Recommended Setting/Value	Priority	Category
58	Alert on bulk data access patterns	Alert: >1000 queries/hour from a single user or token = Warning (potential exfiltration)	Optional	Audit

8. Multi-Environment and Governance

Source: IAM-01, IAM-08

#	Best Practice	Recommended Setting/Value	Priority	Category
59	Adopt the hybrid governance model	Central IAM team owns: account-level policies, production access, policy templates, audit. Team leads own: non-prod access, group membership	Recommended	Governance
60	Restrict account-level permissions to IAM and platform teams	<code>account-iam-admin</code> : IAM team only. <code>account-viewer</code> : limited distribution. No developers with account-level permissions	Critical	Governance
61	Separate production and non-production access into distinct groups	Use environment-specific groups (e.g., <code>dt-prod-checkout-viewers</code> , <code>dt-nonprod-checkout-editors</code>) or environment-scoped policy bindings	Critical	Governance
62	Document and drill break-glass procedures	Written procedure: authorized situations, retrieval steps, notification requirements, mandatory credential rotation after use, post-incident review within 24h	Critical	Governance
63	Synchronize IAM config across environments via config-as-code	Store groups, policies, boundaries in git. Deploy with Monaco or Terraform. PR > review > test in dev > staging > production	Recommended	Governance
64	Require all IAM changes to go through change management	Process: Request (ticket) > Review (IAM admin) > Approval (security lead) > Implementation > Verification > Documentation	Critical	Governance
65	Maintain an up-to-date IAM documentation set	Required: Access Policy (annual), Group Catalog (quarterly), Policy Inventory (quarterly), Boundary Definitions (quarterly), Onboarding/Offboarding Guides	Recommended	Governance
66	Define RACI matrix for IAM operations	Account Admin = Accountable, IAM Admin = Responsible, Env Admin = Consulted, Auditor = Informed for all IAM activities	Recommended	Governance

9. Troubleshooting and Operations

Source: IAM-09, IAM-12

#	Best Practice	Recommended Setting/Value	Priority	Category
67	Follow the 8-step diagnostic methodology for every access issue	1) Authenticate 2) User exists 3) Correct groups 4) Policies grant access 5) Conditions met 6) Boundary allows 7) No conflicts 8) Data exists	Recommended	Operations

#	Best Practice	Recommended Setting/Value	Priority	Category
68	Collect standard information before troubleshooting	Required: user email, exact error message, action attempted, timestamp, recent changes (role, team, IdP)	Recommended	Operations
69	Use SAML tracer browser extension for SSO debugging	Check: NameID format = email, groups attribute present, assertion not expired, signature valid	Recommended	Operations
70	Define a 4-level escalation path	L1: Team lead. L2: IAM admin (policy/boundary changes). L3: Platform team (IdP/infrastructure). L4: Dynatrace support (product issues)	Recommended	Operations
71	Use the IAM API to programmatically validate bindings	GET <code>/iam/v1/repo/{levelType}/{levelId}/bindings/{policyUuid}</code> to dump and compare parameter values	Optional	Operations
72	Verify security context values match templated policy parameters	DQL: <code>fetch dt.entity.service</code> and check <code>dt.security_context</code> values match <code>\${bindParam:...}</code> binding values exactly	Critical	Operations

Summary

This notebook consolidates **72 best practices** across 9 categories from the IAM series (IAM-01 through IAM-12). Use it as:

- **Pre-deployment checklist** -- work through all Critical items before production
- **Quarterly audit sheet** -- verify Recommended items are in place
- **Onboarding reference** -- new IAM administrators start here

Priority Distribution

Priority	Count	Action
Critical	30	Must implement before production
Recommended	36	Implement for enterprise-grade operations
Optional	6	Beneficial for mature or compliance-heavy organizations

Cross-References

Notebook	Focus
IAM-01	Governance framework, ABAC model, roles
IAM-02	SSO, SAML 2.0, MFA
IAM-03	Group hierarchy, naming, SAML mapping
IAM-04	Policy syntax, conditions, patterns

Notebook	Focus
IAM-05	Boundaries, three-domain model, buckets
IAM-06	SCIM, JIT, onboarding/offboarding, external users
IAM-07	Audit logs, SOC2/SOX/HIPAA/PCI-DSS
IAM-08	Multi-environment, break-glass, config sync
IAM-09	Troubleshooting methodology, diagnostic queries
IAM-10	Templated policies, <code>\${bindParam:...}</code> , API bindings
IAM-12	API provisioning scripts, DQL validation

This notebook was AI-generated from community-submitted and publicly available sources. This notebook series is not officially supported by Dynatrace. Always verify information against official Dynatrace documentation.